SICHERHEITSBEFUND · E-MAIL, DOMAIN UND WEBSITE

sollich.com

Unabhängige Prüfung der von außen sichtbaren Sicherheit von sollich.com. Automatisierte Analyse mit scan.reineke.tech.

Sicherheitslücken schließen, bevor sie teuer werden.

ERSTELLT VON

Reineke Technik GmbH
Geseker Straße 26 · 33154 Salzkotten
www.reineke-technik.de

PRÜFDATUM

30. Oktober 2026
Bericht-Nr. RT-DS-00000000-0000

VERTRAULICH

Nur für den internen Gebrauch der Adressaten bestimmt.

Inhalt

Für die Geschäftsführung: Kapitel 01 bis 04. Für Ihre IT: Kapitel 05 und der Anhang.

01 **Zusammenfassung** 3

02 **Empfehlungen** 4

Über diesen Befund hinaus: Penetrationstest 4

03 **Über Reineke Technik** 5

04 **Nächster Schritt** 6

Ergebnisbesprechung: Termin direkt aus dem Bericht buchen 6

05 **Feststellungen im Einzelnen** 7

F-01 Adressauskünfte der Domain nicht signiert 7

F-02 Keine Schutzregel für Skripte 7

F-03 Verschlüsselung wird nicht erzwungen 7

F-04 Kein Schutz vor unsichtbarer Einbettung 8

F-05 Gefälschte E-Mails sollen nur aussortiert werden 9

F-06 Digitale E-Mail-Signatur prüfen 9

F-07 Verschlüsselte Zustellung nicht verbindlich 9

F-08 Keine Fehlerberichte zur Verschlüsselung 9

F-09 Fremde Skripte ohne Prüfung auf Veränderungen 9

Bereits umgesetzt 9

A **Messwerte** 10

B **Methodik und Bewertung** 12

01

Zusammenfassung

GESAMTURTEIL

Ausgewertet wurden ausschließlich öffentlich abrufbare Informationen. Es gab keinen Eingriff in Ihre Systeme, keine Anmeldung und keine nennenswerte Last.

Der Handlungsbedarf ist die Gesamtbewertung des Scanners. Er kann höher ausfallen als die Einstufung der einzelnen Feststellungen.

Handlungsbedarf

Hoch

Das heißt:
Lücken zeitnah schließen.

GERING | MITTEL | **HOCH** | KRITISCH

Lücken bei den geprüften Schutzmechanismen sollten zeitnah geschlossen werden, meist mit wenig Aufwand.

E-MAIL · DMARC
Schutz vor gefälschten Absendern

A+

Sehr gut

A B C D F

Gefälschte E-Mails mit Ihrem Absender sollen nur aussortiert werden.

Score 100 · Geprüfter Schutz umgesetzt

DOMAIN · DNSSEC
Echtheit der Adressauskünfte

F

Ungenügend

A B C D **F**

Die Adressauskünfte Ihrer Domain sind nicht gegen Fälschung geschützt.

Score 0 · Wesentlicher Schutz fehlt

WEBSITE · HTTP OBSERVATORY
Schutz Ihrer Website-Besucher

D

Mangelhaft

A B C **D** F

8 von 12 Tests bestanden. Die Note gewichtet nach Schwere.

Score 30 · Zeitnah beheben

NOTENSKALA **A+ bis A−** sehr gut · **B+ bis B−** gut · **C+ bis C−** verbesserungswürdig · **D+ bis D−** mangelhaft · **F** ungenügend

WESENTLICHE FESTSTELLUNGEN

9

Feststellungen insgesamt

HOCH	0
MITTEL	4
GERING	5

F-01 **Adressauskünfte der Domain nicht signiert** — MITTEL
Mit erheblichem Aufwand ließen sich Besucher und E-Mails auf gefälschte Server umleiten.
Seite 7

F-02 **Keine Schutzregel für Skripte** — MITTEL
Eingeschleuster Programmcode würde auf Ihrer Website nicht blockiert.
Seite 7

F-03 **Verschlüsselung wird nicht erzwungen** — MITTEL
In öffentlichen WLANs könnten Verbindungen zu Ihrer Website abgefangen werden.
Seite 7

NÄCHSTER SCHRITT

Ergebnisbesprechung

In 20 Minuten legen wir gemeinsam fest, was zuerst angegangen wird, gern mit Ihrer IT. Kostenfrei und unverbindlich.

Termin wählen

02

Empfehlungen

Details zu den Feststellungen: Kapitel 05 ab Seite 7.

NR.	DRINGLICHKEIT	MASSNAHME	AUFWAND BEZUG
M-1	MITTEL	**Website-Schutzregeln ergänzen und verschärfen** Betroffen: Content Security Policy, HSTS, X-Frame-Options, Subresource Integrity.	Gering bis mittel F-02, F-03, F-04, F-09 · S. 7–9
M-2	MITTEL	**Adressauskünfte signieren (DNSSEC)** DNSSEC beim DNS-Anbieter aktivieren, DS-Eintrag dort hinterlegen, wo die Domain registriert ist.	Gering F-01 · S. 7
M-3	GERING	**E-Mail-Absender absichern** DMARC-Richtlinie auf „reject“ anheben; DKIM-Schlüssel je Selektor prüfen, nicht mehr genutzte entfernen.	Gering F-05, F-06 · S. 9
M-4	GERING	**Verschlüsselte E-Mail-Zustellung absichern** MTA-STS einrichten, damit E-Mails an Sie nur verschlüsselt zugestellt werden dürfen; TLS-RPT einrichten, damit Probleme bei der verschlüsselten Zustellung gemeldet werden.	Gering bis mittel F-07, F-08 · S. 9
M-5	Abschluss	**Umsetzung überprüfen** Nach der Umsetzung prüfen wir kostenfrei erneut. Der neue Befund zeigt, was behoben ist.	Kostenfrei Alle

PENETRATIONSTEST

Extern
Aus dem Internet erreichbare Systeme und Dienste

Intern / Active Directory
Firmennetz, Berechtigungen, Rechteausweitung

Webanwendung
Portale, Shops und Kundenzugänge

Über diesen Befund hinaus: Penetrationstest

Dieser Befund zeigt einen Ausschnitt dessen, was von außen sichtbar ist. Ein Penetrationstest klärt, was ein Angreifer erreicht, wenn er Schwachstellen zu einem Angriffspfad verkettet. Sie erhalten priorisierte Maßnahmen und einen Nachweis für Kunden und Prüfer.

1 **Vorbereitung**
Ziele, Systeme und Prüftiefe festlegen, Zeitfenster betriebsschonend abstimmen.

2 **Test**
Manuell und mit eigenen Werkzeugen, jeder Schritt nachvollziehbar dokumentiert.

3 **Bericht und Besprechung**
Priorisierte Feststellungen mit konkreten Behebungsempfehlungen.

4 **Nachtest**
Nach Ihrer Nachbesserung prüfen wir die Wirksamkeit erneut.

Umfang und Anfrage: scan.reineke.tech/pentest

03

Über Reineke Technik



Werner Francis Reineke

Geschäftsführer, Reineke Technik GmbH

Reineke Technik prüft die IT-Sicherheit mittelständischer Industrie- und Produktionsunternehmen und unterstützt bei Anforderungen wie NIS-2, ISO 27001 und TISAX.

Wir haben Netzwerke selbst aufgebaut und betrieben. Diese Praxis fließt in jede Prüfung ein: Wir wissen, wo Angreifer ansetzen und wo im Betriebsalltag Lücken entstehen.

„Sicherheitslücken schließen, bevor sie teuer werden.“

Unabhängig
Wir prüfen Systeme, die wir nicht selbst betreiben, und verkaufen keine Technik, die wir anschließend kontrollieren.

Verständlich
Jeder Bericht enthält eine Zusammenfassung für die Geschäftsführung und einen priorisierten Maßnahmenplan.

Nachweisbar
Nach der Behebung prüfen wir erneut. So wird Sicherheit gegenüber Kunden und Prüfern belegbar.

KUNDEN

47

Unternehmen seit Gründung, überwiegend Industrie und Zulieferer

FACHVORTRÄGE

Live-Hacking

Referent, u. a. in der Cybersecurity-Vortragsreihe von SHARP

STANDORT

Salzkotten

Ostwestfalen-Lippe, vor Ort in NRW

LEISTUNGEN

- Penetrationstests: extern, intern, Webanwendungen
- ISMS-Aufbau nach ISO 27001
- Externes Sicherheitsmandat (eISB / vCISO)
- NIS-2-Bestandsaufnahme der Sicherheitsmaßnahmen
- TISAX-Begleitung für Zulieferer

04

Nächster Schritt

ERGEBNISBESPRECHUNG
sollich.com

In 20 Minuten legen wir gemeinsam fest, was zuerst angegangen wird, gern mit Ihrer IT. Kostenfrei und unverbindlich.

Termin per QR-Code

Termin wählen

SCHRITT
1

Ergebnisbesprechung
Feststellungen einordnen, Prioritäten festlegen.

SCHRITT
2

Umsetzung
Ihre IT oder Ihr IT-Dienstleister, auf Wunsch mit unserer fachlichen Begleitung.

SCHRITT
3

Kontrolle
Wiederholungsprüfung, auf Wunsch Penetrationstest.

ANSPRECHPARTNER



Werner Francis Reineke
Geschäftsführer
wf.reineke@reineke-technik.de
+49 172 2872390

Karl Pieper
Geschäftsführer
k.pieper@reineke-technik.de
+49 5259 9870
+49 172 5209052 (mobil)

REINEKE

ANSCHRIFT
Reineke Technik GmbH
Geseker Straße 26
33154 Salzkotten
www.reineke-technik.de

PENETRATIONSTEST ANFRAGEN
scan.reineke.tech/pentest

Amtsgericht Paderborn · HRB 15938 · Geschäftsführer: Werner Francis Reineke, Karl Pieper · USt-IdNr. DE353762579

05

Feststellungen im Einzelnen

Zu jeder Feststellung: was wir festgestellt haben, was ein Angreifer damit erreichen kann und was das für Sie bedeutet.

F-01

MITTEL

Adressauskünfte der Domain nicht signiert

Domain · DNSSEC · Maßnahme M-2

FESTSTELLUNG

Die Adressauskünfte Ihrer Domain (DNS), unter welcher Adresse Website und Mailserver erreichbar sind, tragen keine digitale Signatur (DNSSEC).

ANGRIFFSSZENARIO

Mit erheblichem Aufwand lassen sich Adressauskünfte fälschen und, ohne MTA-STS, E-Mails umleiten. Besucher schützt vor allem erzwungenes HTTPS.

AUSWIRKUNG FÜR SIE

E-Mails an Sie oder Eingaben Ihrer Besucher könnten abgefangen werden.

AUFWAND

Gering. Meist beim DNS-Anbieter einschaltbar, dazu ein Eintrag beim Domain-Anbieter.

TECHNISCHER BEFUND

`DNSSEC: Zone nicht signiert`

F-02

MITTEL

Keine Schutzregel für Skripte

Website · Content Security Policy · Maßnahme M-1

FESTSTELLUNG

Die Website legt nicht fest, welcher Programmcode ausgeführt werden darf (Content Security Policy fehlt).

ANGRIFFSSZENARIO

Gelingt es, Code einzuschleusen, etwa über ein Formular oder ein veraltetes Plugin, wird er nicht blockiert. Er kann Eingaben mitlesen oder Besucher umleiten.

AUSWIRKUNG FÜR SIE

Ihre Website könnte gegen Ihre eigenen Besucher eingesetzt werden.

AUFWAND

Mittel. Erfordert Abstimmung mit der Website-Entwicklung.

TECHNISCHER BEFUND

`Content Security Policy (CSP): −25 Punkte · „Content-Security-Policy-Header nicht implementiert.“`

F-03

MITTEL

Verschlüsselung wird nicht erzwungen

Website · HSTS · Maßnahme M-1

FESTSTELLUNG

Die Website weist Browser nicht an, ausschließlich verschlüsselt zu verbinden (HSTS).

ANGRIFFSSZENARIO

In öffentlichen WLANs (Hotel, Messe, Bahn) kann der erste Aufruf auf eine unverschlüsselte Verbindung umgeleitet und mitgelesen werden.

AUSWIRKUNG FÜR SIE

Formulareingaben und Anmeldedaten könnten dort mitgelesen werden.

AUFWAND

Gering. Eine Zeile in der Serverkonfiguration.

TECHNISCHER BEFUND

`HSTS (Strict-Transport-Security): −20 Punkte · „Strict-Transport-Security-Header nicht implementiert.“`

F-04

MITTEL

Kein Schutz vor unsichtbarer Einbettung

Website · X-Frame-Options · Maßnahme M-1

FESTSTELLUNG

Die Website kann unsichtbar in fremde Webseiten eingebettet werden (X-Frame-Options bzw. frame-ancestors fehlt).

ANGRIFFSSZENARIO

Angreifer könnten Besucher unbemerkt Aktionen auf Ihrer Website auslösen lassen (Clickjacking).

AUSWIRKUNG FÜR SIE

Vorhandene Formulare oder Konten könnten missbraucht werden.

AUFWAND

Gering. Eine Zeile in der Serverkonfiguration.

TECHNISCHER BEFUND

`X-Frame-Options: -20 Punkte · „X-Frame-Options-Header (XFO) nicht implementiert.“`

GERING

Weitere Feststellungen

F-05
E-Mail · DMARC

Gefälschte E-Mails sollen nur aussortiert werden
Gefälschte E-Mails landen im Spam-Ordner, statt abgewiesen zu werden.
Aufwand gering: Richtlinie auf „reject“ anheben.

F-06
E-Mail · DKIM

Digitale E-Mail-Signatur prüfen
Die Prüfung bestätigt die E-Mail-Signatur nicht als einwandfrei.
Aufwand gering: Länge und Nutzung je Schlüssel prüfen, ungenutzte entfernen.

F-07
E-Mail · MTA-STS

Verschlüsselte Zustellung nicht verbindlich
E-Mails an Sie können auf dem Transportweg unverschlüsselt übertragen werden.
Aufwand gering bis mittel: Richtliniendatei mit gültigem Zertifikat und DNS-Eintrag anlegen.

F-08
E-Mail · TLS-RPT

Keine Fehlerberichte zur Verschlüsselung
Sie erfahren nicht, wenn verschlüsselte Zustellung scheitert.
Aufwand gering: Ein DNS-Eintrag.

F-09
Website · Subresource Integrity

Fremde Skripte ohne Prüfung auf Veränderungen
Fremder Programmcode wird geladen, ohne zu prüfen, ob er verändert wurde.
Aufwand gering: Prüfsummen für externe Skripte ergänzen.

Technische Einzelwerte zu allen Feststellungen in Anhang A, Maßnahmen in Kapitel 02.

BEREITS UMGESETZT

3
Punkte

Ihr DMARC-Eintrag weist Mailserver an, E-Mails mit gefälschtem Absender abzuweisen oder auszusortieren: ein wesentlicher Baustein gegen Rechnungs- und Chef-Betrug.

- Gefälschte E-Mails sollen aussortiert werden (DMARC „quarantine“)
- Auswertungsberichte angefordert (DMARC)
- Berechtigte Mailserver festgelegt (SPF)

A Messwerte

PRÜFUNG	ERGEBNIS	MESSWERT
E-MAIL		
DMARC	A+ Score 100	`v=DMARC1;p=quarantine;pct=100;rua=mailto:Mailbox-DMARC@sollich.com;ruf=mailto:Mailbox-DMARC@sollich.com;ri=84600;fo=1` Richtlinie (p): quarantine · Berichte (rua): angefordert
SPF	OK	SPF korrekt (4/10 Lookups).
DKIM	HINWEIS	1 DKIM-Selektor gefunden
MX (Mailserver)	HINWEIS	1 MX-Server gefunden
MTA-STS	HINWEIS	Kein MTA-STS
TLS-RPT	HINWEIS	Kein TLS-RPT
DOMAIN		
DNSSEC	F Score 0	Zone nicht signiert

ANHANG A

Messwerte, Fortsetzung

PRÜFUNG	ERGEBNIS	MESSWERT
WEBSITE		
HTTP Observatory	**D** Score 30	8 von 12 Tests bestanden. Tests mit Abzug:
Content Security Policy (CSP)	**−25**	Content-Security-Policy-Header nicht implementiert. Empfehlung: CSP einführen — siehe MDN-Dokumentation zu Content Security Policy.
HSTS (Strict-Transport-Security)	**−20**	Strict-Transport-Security-Header nicht implementiert. Empfehlung: HSTS hinzufügen, ggf. zunächst mit kürzeren Zeiträumen (siehe hstspreload.org).
X-Frame-Options	**−20**	X-Frame-Options-Header (XFO) nicht implementiert. Empfehlung: frame-ancestors per CSP umsetzen.
Subresource Integrity (SRI)	**−5**	Subresource Integrity (SRI) nicht implementiert, aber alle externen Skripte werden über HTTPS geladen. Empfehlung: SRI für externe Skripte ergänzen.
Cookies	**0**	Keine Cookies erkannt. Empfehlung:
coep	**0**	Cross-Origin-Embedder-Policy header not implemented. Empfehlung: Set to require-corp or credentialless.
coop	**0**	Cross-Origin-Opener-Policy header not implemented. Empfehlung: Set to same-origin, same-origin-allow-popups, or noopener-allow-popups.
CORS	**0**	Inhalte sind nicht per Cross-Origin Resource Sharing (CORS) sichtbar. Empfehlung:
Weiterleitung auf HTTPS	**0**	Erste Weiterleitung geht per HTTPS auf denselben Host, Endziel ist HTTPS. Empfehlung:
Referrer-Policy	**0**	Referrer-Policy-Header nicht implementiert. Empfehlung: Mindestens auf strict-origin-when-cross-origin setzen.
X-Content-Type-Options	**0**	X-Content-Type-Options auf nosniff gesetzt. Empfehlung:
Cross-Origin-Resource-Policy	**0**	Cross-Origin Resource Policy (CORP) nicht implementiert (Standard: cross-origin). Empfehlung:

B

Methodik und Bewertung

VORGEHEN

Alle Werte wurden am 30. Oktober 2026 automatisiert mit scan.reineke.tech erhoben, DNS-Abfragen über Cloudflare DNS-over-HTTPS (1.1.1.1). DKIM lässt sich nur über gängige Selektoren prüfen. Die Website-Bewertung nutzt den MDN HTTP Observatory von Mozilla und gilt nur für die Startseite, nicht für Portale oder Subdomains. Ausgewertet wurden nur öffentlich abrufbare Informationen, ohne Anmeldung, Eingriff oder nennenswerte Last. Die Ergebnisse sind eine Momentaufnahme; auf Anfrage prüfen wir kostenfrei erneut.

E-Mail DMARC, SPF, DKIM, MX, MTA-STS, TLS-RPT	DMARC legt fest, wie Mailserver mit E-Mails umgehen sollen, die Ihre Absenderadresse nur vortäuschen: „reject“ weist ab, „quarantine“ sortiert aus, „none“ beobachtet nur. SPF und DKIM liefern die Prüfgrundlage.
Domain DNSSEC	DNSSEC signiert die Adressauskünfte Ihrer Domain. Prüfende DNS-Server erkennen so Fälschungen, die E-Mails oder Besucher umleiten könnten.
Website MDN HTTP Observatory	Der HTTP Observatory von Mozilla prüft die Schutzregeln Ihrer Website, etwa CSP und HSTS. Die Note ergibt sich aus gewichteten Punktabzügen.

NOTENSKALA

A+ / A / A−	SEHR GUT	Geprüfter Schutz umgesetzt
B+ / B / B−	GUT	Geringfügige Verbesserungen möglich
C+ / C / C−	VERBESSERUNGSWÜRDIG	Bei nächster Gelegenheit angehen
D+ / D / D−	MANGELHAFT	Zeitnah beheben
F	UNGENÜGEND	Wesentlicher Schutz fehlt

Vertraulich – bestimmt für den Inhaber der geprüften Domain und dessen IT-Dienstleister.